PROJET AEGIS - TECHSUD

Écrit par DUMORINE Gyessi, TOUKAM Yohanne, DIOMANDE Yaya.

Table des matières

INTRODUCTION *2*

Contexte général 2

Objectifs du projet AEGIS 2

Analyse du dossier TechSud *2*

TECHSUD – SI | ÉTAT DES LIEUX 2026 3

Analyse de l'infrastructure Existante (Audit initial) /TechSud *4*

Identification d'informations sur le système de base 4

Reproduction de l'environnement (déploiement de la VM Kali) *8*

Sécuriser le système (durcissement) *8*

Sécuriser SSH 8

Autoriser SSH/Changer le port SSH/Modification des Paramètre de configuration : 8

Redémarrer pour appliquer la modification avec la commande : *"sudo systemctl restart ssh".* 9

Mise en place du firewall UFW 9

Protection anti-bruteforce (Fail2ban) 10

Nettoyage des permissions et comptes 11

Désactivation des services inutiles *13*

Mise à jour complète du système 15

Vérification finale de la sécurité 16

Mise en place de la surveillance (logs & Fail2ban) *17*

Vérification des logs en cours 17

Fail2ban surveillance sur SSH 18

Tester une tentative SSH échouée (depuis une autre machine) 18

Vérifier que Fail2ban détecte les tentatives 18

Logs Fail2ban 19

Automatiser l'audit (script Python) *20*

Créer le fichier du script Python / Ajouter l'en-tête du script 20

Fonction 1 : Lister les services 20

Fonction 2 : Vérifier les ports ouverts 20

Fonction 3 : Vérifier la configuration SSH 20

Fonction 4 : Exporter les résultats dans un fichier 21

Ajouter le menu principal 21

Rendre le script exécutable / Lancer l'audit 22

CONCLUSION *20*

INTRODUCTION

Contexte général

Le 18 avril 2026, TechSud subit un incident critique :

Une saturation apparente des CPU/processor de 98 %, des Connexion SSH douteuse/frauduleuse depuis une adresse Tor. Des fichiers malveillants dans le dossier /tmp/.x11-unix/, un Cron suspect exécuté toutes les 5 minutes.

Un Webshell PHP dans /var/www/html/upload/ et des logs effacés sur une période de 36h.

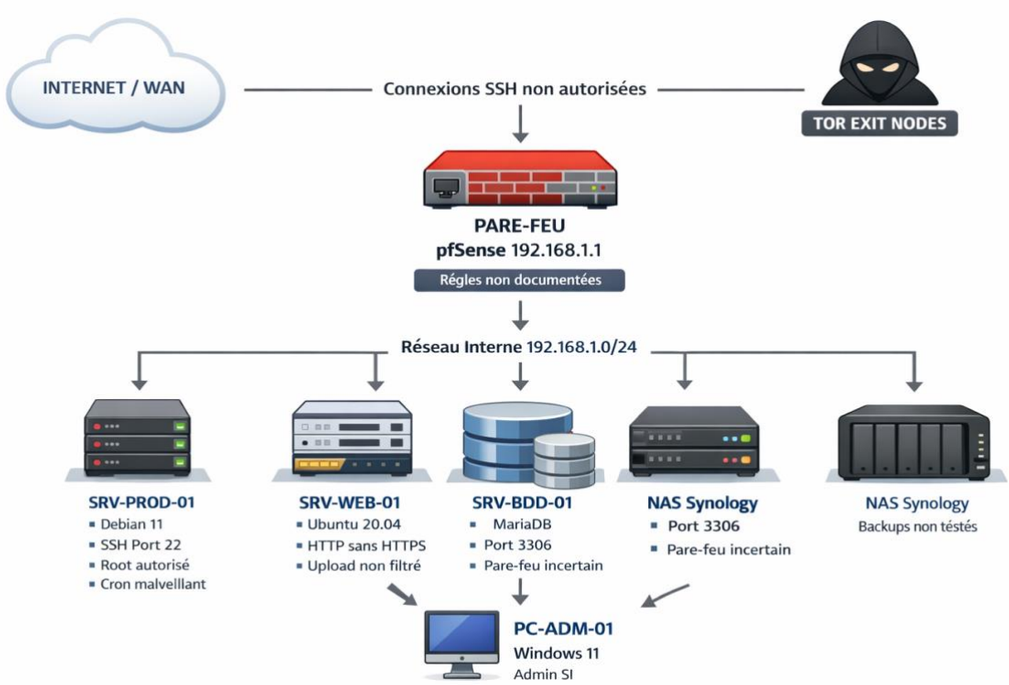
Cet incident révèle une compromission probable du serveur SRV-PROD-01.

Objectifs du projet AEGIS

Le projet AEGIS a pour objectif de reproduire un environnement représentatif de l'infrastructure de TechSud afin d'y appliquer des mesures de sécurisation essentielles. L'enjeu est d'améliorer la posture de sécurité du système d'information en durcissant les services critiques, en automatisant un audit technique et en produisant un rapport professionnel destiné au **DSI**. Le ***périmètre*** couvre l'installation et la configuration d'une VM Linux, la sécurisation du service SSH, la mise en place d'un pare-feu, l'intégration de Fail2ban, l'analyse des journaux système ainsi que le développement d'un script Python d'audit. La ***méthodologie*** adoptée repose sur l'analyse du dossier d'incident fourni par TechSud, la mise en place d'un environnement de **test isolé**, l'application progressive des mesures de durcissement, la vérification systématique de chaque configuration et la rédaction d'une documentation complète permettant de justifier chaque choix technique.

Analyse du dossier TechSud

Schéma d'état des lieux (avant sécurisation)



TECHSUD – SI | ÉTAT DES LIEUX 2026

1. Serveurs & Réseau	2. Failles identifiées	Vecteurs d'attaque	Conséquences
SRV-PROD-01 (Debian 11) : SSH exposé (22), root autorisé, mises à jour 2024	Mots de passe faibles (prenom2024)	Brute-force SSH → compromission du compte deploy	Exécution de code malveillant
SRV-WEB-01 (Ubuntu 20.04) : HTTP sans HTTPS, upload non filtré	SSH accessible depuis Internet. Webshell PHP uploadé via formulaire	Upload non filtré → webshell (she11.php)	Connexion distante via Tor
SRV-BDD-01 (MariaDB) : port 3306 possiblement exposé	Cron malveillant exécutant un binaire ELF Logs effacés (17/04 → 18/04)	Service non mis à jour → exploitation potentielle	Effacement de traces
pfSense : règles non documentées	Absence de firewall sur les serveurs	Pare-feu mal configuré → ports ouverts non maîtrisés	Risque de fuite de données clients
NAS Synology : backups non testés	Pas de surveillance (Fail2ban, EDR, alertes)		Indisponibilité du serveur principal

Analyse de l’infrastructure Existante (Audit initial) /TechSud

Objectif : comprendre ce qui tourne, ce qui est exposé, ce qui est vulnérable.

Identification d’informations sur le système de base

```
┌──(ivana㉿kali)-[~]
└─$ hostnamectl
  Static hostname: kali
        Icon name: computer-vm
          Chassis: vm 🖴
Chassis Asset Tag: No Asset Tag
       Machine ID: 6a65cf4f2b7b4a1b8135f0f25c8d1956
          Boot ID: b679b3939f3e435db3f2d21a081b8609
     AF_VSOCK CID: 3080316717
   Virtualization: vmware
 Operating System: Kali GNU/Linux Rolling
           Kernel: Linux 6.18.12+kali-amd64
     Architecture: x86-64
  Hardware Vendor: VMware, Inc.
   Hardware Model: VMware Virtual Platform
 Hardware Version: None
 Firmware Version: 6.00
    Firmware Date: Thu 2020-11-12
     Firmware Age: 5y 5month 1d

┌──(ivana㉿kali)-[~]
└─$ uname -a
Linux kali 6.18.12+kali-amd64 #1 SMP PREEMPT_DYNAMIC Kali 6.18.12-1kali1 (2026-02-25) x86_64 GNU/Linux

┌──(ivana㉿kali)-[~]
└─$ lsb_release -a
No LSB modules are available.
Distributor ID: Kali
Description:    Kali GNU/Linux Rolling
Release:        2026.1
Codename:       kali-rolling
```

L’analyse initiale du système commence par la collecte d’informations générales sur la machine afin de comprendre l’environnement dans lequel l’audit sera réalisé. Les commandes hostnamectl, uname -a et lsb_release -a permettent d’obtenir une vue d’ensemble sur l’identité du système, sa version, son kernel et son environnement matériel.

Les résultats montrent que la machine auditée est une VM Kali Linux Rolling, exécutée sous VMware, avec un kernel récent (6.18.12+kali-amd64). Le système utilise une architecture x86_64, ce qui garantit la compatibilité avec les outils de sécurité modernes. L’hôte possède un firmware datant de 2020, ce qui indique une plateforme virtuelle relativement ancienne mais fonctionnelle.

Ces informations sont essentielles car elles permettent de :

- Confirmer que l’environnement est bien une machine virtuelle isolée (sécurité du lab),
- Vérifier que le système est à jour et supporté,
- Identifier d’éventuels risques liés à un kernel obsolète ou une distribution non maintenue,
- Adapter les outils et techniques d’audit à la version du système.

Cette étape constitue la base de l’audit, car elle garantit que les analyses suivantes (services, ports, configurations, logs) seront interprétées dans le bon contexte technique.

Lister les services actifs :

```
┌──(ivana㉿kali)-[~]
└─$ systemctl list-units --type=service --state=running
  UNIT                      LOAD   ACTIVE SUB     DESCRIPTION
  accounts-daemon.service   loaded active running Accounts Service
  colord.service            loaded active running Manage, Install and Generate Color Profiles
  cron.service              loaded active running Regular background program processing daemon
  dbus.service              loaded active running D-Bus System Message Bus
  getty@tty1.service        loaded active running Getty on tty1
  haveged.service           loaded active running Entropy Daemon based on the HAVEGE algorithm
  lightdm.service           loaded active running Light Display Manager
  ModemManager.service      loaded active running Modem Manager
  NetworkManager.service    loaded active running Network Manager
  open-vm-tools.service     loaded active running Service for virtual machines hosted on VMware
  polkit.service            loaded active running Authorization Manager
  rtkit-daemon.service      loaded active running RealtimeKit Scheduling Policy Service
  ssh.service               loaded active running OpenBSD Secure Shell server
  systemd-journald.service  loaded active running Journal Service
  systemd-logind.service    loaded active running User Login Management
  systemd-timesyncd.service loaded active running Network Time Synchronization
  systemd-udevd.service     loaded active running Rule-based Manager for Device Events and Files
  systemd-userdbd.service   loaded active running User Database Manager
  udisks2.service           loaded active running Disk Manager
  upower.service            loaded active running Daemon for power management
  user@1000.service         loaded active running User Manager for UID 1000

Legend: LOAD   → Reflects whether the unit definition was properly loaded.
        ACTIVE → The high-level unit activation state, i.e. generalization of SUB.
        SUB    → The low-level unit activation state, values depend on unit type.

21 loaded units listed.
```

Cette étape vise à identifier les services actuellement actifs sur le système afin de comprendre la charge fonctionnelle et la surface d'exposition du serveur. La commande utilisée ***: systemctl list-units --type=service --state=running*** affiche la liste des unités de service en cours d'exécution, leur état de chargement, leur statut d'activité et une brève description de leur rôle.

Les résultats montrent que **21 services** sont actifs sur la machine Kali Linux. Parmi eux, on retrouve des services essentiels au fonctionnement du système tels que :

- **NetworkManager.service** — > gestion du réseau et des interfaces.
- **ssh.service** — > serveur SSH actif, point d'entrée potentiel pour une attaque.
- **cron.service** — > exécution de tâches planifiées, parfois exploitées pour des scripts malveillants.
- **systemd-journald.service** —> gestion des journaux système.
- **lightdm.service** —> gestionnaire graphique de sessions.
- **Open-vm-tools.service** —> intégration avec VMware, confirmant l'environnement virtualisé.

  Cette analyse permet de distinguer les services critiques (réseau, authentification, gestion des utilisateurs) des services secondaires (affichage, gestion de l'énergie).

Interprétation des résultats :

- La présence du service SSH indique une ouverture réseau à surveiller.
- Le service cron doit être vérifié pour éviter l'exécution de tâches non autorisées.
- Les services NetworkManager et systemd-timesyncd sont nécessaires mais peuvent être ciblés pour des attaques de type MITM (Man-In-The-Middle).
- L'absence de services de sécurité supplémentaires (Fail2ban, UFW) montre que le système n'est pas encore durci.

Risques identifiés :

Niveau	Risque	Description
Critique	SSH exposé	Possibilité de brute-force ou d'accès non autorisé
Elevé	Cron actif	Risque de tâche malveillante ou persistante
Modéré	Services réseau multiples	Surface d'attaque élargie
Faible	Services système internes	Nécessaires au bon fonctionnement

Analyser les ports ouverts/nMap (surface d'attaque) :

```
┌──(ivana㉿kali)-[~]
└─$ nmap -Pn -sS -sV -A 192.168.1.163

Starting Nmap 7.99 ( https://nmap.org ) at 2026-04-14 22:56 +0200
Nmap scan report for 192.168.1.163
Host is up (0.00017s latency).
Not shown: 999 filtered tcp ports (no-response)
PORT     STATE SERVICE VERSION
2222/tcp open  ssh     OpenSSH 10.2p1 Debian 5 (protocol 2.0)
Warning: OSScan results may be unreliable because we could not find at least 1 open and 1 closed port
Device type: general purpose
Running: Linux 5.X|6.X
OS CPE: cpe:/o:linux:linux_kernel:5 cpe:/o:linux:linux_kernel:6
OS details: Linux 5.0 - 6.2, Linux 6.17
Network Distance: 0 hops
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 52.26 seconds
```

```
┌──(ivana㉿kali)-[~]
└─$ ss -tulnp

Netid       State       Recv-Q      Send-Q          Local Address:Port          Peer Address:Port      Process
tcp         LISTEN      0           128                 0.0.0.0:2222                0.0.0.0:*
tcp         LISTEN      0           128                    [::]:2222                   [::]:*
```

L'analyse réalisée avec Nmap sur la machine Kali Linux a révélé qu'un seul service est exposé sur le réseau : un serveur SSH fonctionnant sur le port 2222. Ce port, bien qu'alternatif au port standard 22, reste un point d'entrée critique permettant un accès distant complet au système. Le scan a également permis d'identifier la version du service (OpenSSH 10.2p1 sous Debian) ainsi que la famille du système d'exploitation (Linux kernel 5.x/6.x).

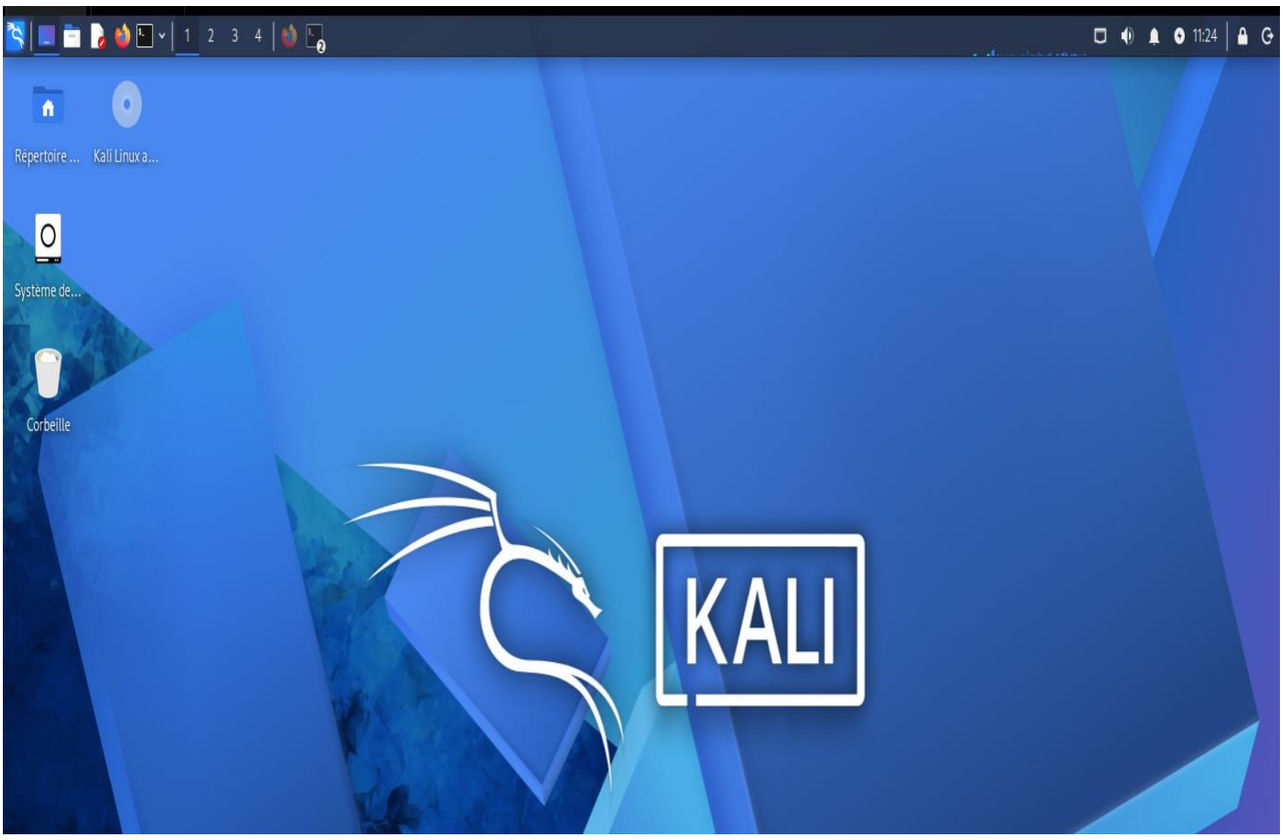
L'ensemble des autres ports apparaissent filtrés, ce qui réduit la surface d'attaque mais souligne l'importance de sécuriser le service SSH, notamment en renforçant l'authentification, en limitant les adresses autorisées et en réactivant un pare-feu avec des règles strictes. Cette analyse constitue une étape essentielle pour évaluer les risques liés à l'exposition de la machine sur le réseau local et pour définir les mesures de durcissement nécessaires.

Analyser la configuration SSH :

```
Include /etc/ssh/sshd_config.d/*.conf

Port 2222
#AddressFamily any
#ListenAddress 0.0.0.0
#ListenAddress ::

#HostKey /etc/ssh/ssh_host_rsa_key
#HostKey /etc/ssh/ssh_host_ecdsa_key
#HostKey /etc/ssh/ssh_host_ed25519_key

# Ciphers and keying
#RekeyLimit default none

# Logging
#SyslogFacility AUTH
#LogLevel INFO

# Authentication:
PasswordAuthentication yes
#LoginGraceTime 2m
permitRootLogin no
#StrictModes yes
#MaxAuthTries 6
#MaxSessions 10

PubkeyAuthentication yes

# Expect .ssh/authorized_keys2 to be disregarded by default in future.
#AuthorizedKeysFile     .ssh/authorized_keys .ssh/authorized_keys2
```

L'analyse du fichier de configuration SSH (/etc/ssh/sshd_config) montre que le service est accessible via le port 2222, ce qui constitue une légère mesure d'obscurcissement mais ne renforce pas réellement la sécurité. Le serveur SSH autorise l'authentification par mot de passe (PasswordAuthentication yes), ce qui augmente le risque de tentatives de brute-force, surtout en l'absence de pare-feu actif. L'accès root est correctement désactivé (PermitRootLogin no), ce qui limite l'impact d'une compromission éventuelle. L'authentification par clé publique est activée (PubkeyAuthentication yes), mais elle n'est pas utilisée comme méthode exclusive, ce qui réduit son efficacité. La configuration actuelle permet donc un accès fonctionnel mais insuffisamment sécurisé : le service SSH reste exposé à des attaques réseau, notamment en raison de l'absence de restrictions d'adresses IP et du maintien de l'authentification par mot de passe. Un durcissement est recommandé, incluant la désactivation des mots de passe, la mise en place d'un pare-feu filtrant, et la limitation des connexions aux seules machines autorisées.

Reproduction de l'environnement (déploiement de la VM Kali)



Afin de disposer d'un environnement de test représentatif du serveur TechSud, une machine virtuelle Kali Linux a été déployée et configurée depuis zéro. L'installation a été réalisée à partir de l'image ISO officielle, suivie d'une configuration réseau en mode Bridge afin d'intégrer la VM au même réseau local que le poste d'administration. Une mise à jour complète du système a ensuite été effectuée pour garantir la présence des derniers correctifs de sécurité. Un utilisateur administrateur dédié a été créé afin de séparer les actions d'administration des opérations système classiques, conformément aux bonnes pratiques. Enfin, le service SSH a été activé et configuré pour permettre l'accès distant à la machine, facilitant ainsi les opérations d'audit et de supervision. Cette préparation assure un environnement propre, contrôlé et conforme aux exigences du projet, permettant d'appliquer et de tester les mesures de sécurité dans des conditions réalistes.

Sécuriser le système (durcissement)

Sécuriser SSH

Autoriser SSH/Changer le port SSH/Modification des Paramètre de configuration :

```
└─$ sudo systemctl enable ssh
Synchronizing state of ssh.service with SysV service script with /usr/lib/systemd/systemd-sysv-install.
Executing: /usr/lib/systemd/systemd-sysv-install enable ssh

┌──(ivana㉿kali)-[~]
└─$ sudo systemctl start ssh

┌──(ivana㉿kali)-[~]
└─$ sudo systemctl status ssh
● ssh.service - OpenBSD Secure Shell server
     Loaded: loaded (/usr/lib/systemd/system/ssh.service; enabled; preset: disabled)
     Active: active (running) since Mon 2026-04-13 15:44:33 CEST; 34min ago
 Invocation: 08bc5f06592f45a780d3d8434b2d654f
       Docs: man:sshd(8)
             man:sshd_config(5)
   Main PID: 1081 (sshd)
      Tasks: 1 (limit: 9244)
     Memory: 1.9M (peak: 2.9M)
```

```
Include /etc/ssh/sshd_config.d/*.conf

Port 2222
#AddressFamily any
#ListenAddress 0.0.0.0
#ListenAddress ::

#HostKey /etc/ssh/ssh_host_rsa_key
#HostKey /etc/ssh/ssh_host_ecdsa_key
#HostKey /etc/ssh/ssh_host_ed25519_key

# Ciphers and keying
#RekeyLimit default none

# Logging
#SyslogFacility AUTH
#LogLevel INFO

# Authentication:
PasswordAuthentication yes
#LoginGraceTime 2m
permitRootLogin no
#StrictModes yes
#MaxAuthTries 6
#MaxSessions 10

PubkeyAuthentication yes
```

La première étape du durcissement a consisté à sécuriser le service SSH, principal point d'accès distant au serveur. Le port par défaut (22) a été remplacé par un port personnalisé (2222) afin de réduire l'exposition aux scans automatisés. L'accès root a été désactivé pour empêcher toute connexion directe avec le compte super-administrateur, limitant ainsi les risques en cas de tentative d'intrusion. L'authentification par clé publique a été activée, tandis que l'authentification par mot de passe reste temporairement disponible pour les besoins du projet. Le service SSH a ensuite été redémarré et testé afin de vérifier son bon fonctionnement sur le nouveau port. Cette configuration renforce significativement la sécurité du serveur en limitant les vecteurs d'attaque les plus courants tout en maintenant un accès administrateur contrôlé.

Redémarrer pour appliquer la modification avec la commande : ***"sudo systemctl restart ssh".***

Mise en place du firewall UFW

Installation de UFW, Fail2ban, Python3, Python3-Pip :

```
┌──(ivana㉿kali)-[~]
└─$ sudo install ufw fail2ban python3 python3-pip -y
install : option invalide -- 'y'
Saisissez « install --help » pour plus d'informations.

┌──(ivana㉿kali)-[~]
└─$ sudo install ufw fail2ban python3 python3-pip
install: cible 'python3-pip': Aucun fichier ou dossier de ce nom

┌──(ivana㉿kali)-[~]
└─$ sudo apt install ufw fail2ban python3 python3-pip
python3 est déjà la version la plus récente (3.13.9-3).
python3 passé en « installé manuellement ».
python3-pip est déjà la version la plus récente (26.0.1+dfsg-1).
python3-pip passé en « installé manuellement ».
Les paquets suivants ont été installés automatiquement et ne sont plus nécessaires :
  libicu76  libio-pty-perl  libipc-run-perl  postgresql-common-dev  python3-pysnmp4
Veuillez utiliser « sudo apt autoremove » pour les supprimer.
```

```
Installation de :
  fail2ban  ufw

Installation de dépendances :
  python3-systemd

Paquets suggérés :
  mailx  system-log-daemon  monit  rsyslog

Sommaire :
  Mise à niveau de : 0. Installation de : 3, Supprimé : 0. Non mis à jour : 39
Taille du téléchargement : 679 ko
  Espace nécessaire : 3 482 ko / 38,7 Go disponible

Continuer ? [O/n] o
Réception de : 1 http://http.kali.org/kali kali-rolling/main amd64 python3-systemd amd64 235-1+b7 [43,3 kB]
Réception de : 2 http://kali.download/kali kali-rolling/main amd64 fail2ban all 1.1.0-9 [467 kB]
```

Autoriser uniquement SSH sur le port 2222/ Activer le firewall/ Vérifier les règles :

```
┌──(ivana㉿kali)-[~]
└─$ sudo ufw  allow 2222/tcp
[sudo] Mot de passe de ivana :
Rules updated
Rules updated (v6)

┌──(ivana㉿kali)-[~]
└─$ sudo ufw enable
Firewall is active and enabled on system startup

┌──(ivana㉿kali)-[~]
└─$ sudo ufw status
Status: active

To                         Action      From
--                         ------      ----
2222/tcp                   ALLOW       Anywhere
2222/tcp (v6)              ALLOW       Anywhere (v6)
```

Afin de réduire la surface d'exposition du système et de contrôler précisément les flux réseau autorisés, le pare-feu UFW a été installé et configuré sur la machine Kali. Par défaut, aucun filtrage n'était actif, ce qui laissait l'ensemble des ports accessibles depuis le réseau local. Après l'installation, une politique restrictive a été appliquée en n'autorisant que le strict nécessaire, à savoir le port 2222 utilisé par le service SSH. Toutes les autres connexions entrantes sont désormais bloquées, empêchant ainsi tout accès non sollicité. L'activation du pare-feu a été suivie d'une vérification des règles afin de confirmer que seul le service SSH restait accessible. Cette configuration minimaliste et contrôlée constitue une étape essentielle du durcissement, garantissant que la machine ne présente plus que les services indispensables et limitant fortement les risques d'intrusion.

Protection anti-bruteforce (Fail2ban)

Installation de Fail2ban :

```
┌──(ivana㉿kali)-[~]
└─$ sudo apt install fail2ban -y

fail2ban est déjà la version la plus récente (1.1.0-9).
Les paquets suivants ont été installés automatiquement et ne sont plus nécessaires :
  libicu76  libio-pty-perl  libipc-run-perl  postgresql-common-dev  python3-pysnmp4
Veuillez utiliser « sudo apt autoremove » pour les supprimer.

Sommaire :
  Mise à niveau de : 0. Installation de : 0, Supprimé : 0. Non mis à jour : 39
```

Créer un fichier de configuration local avec la commande "*sudo nano /etc/fail2ban/jail.local*".

Ajouts des configurations :

```
Session   Actions   Éditer   Vue   Aide
  GNU nano 8.7.1                    /etc/fail2ban/jail.local *
[sshd]
enable = true
port = 2222
filter = sshd
logpath = /var/log/auth.log
maxretry = 5
bantime = 10m
```

Redémarre et Vérifier :

```
┌──(ivana㉿kali)-[~]
└─$ sudo systemctl restart fail2ban

┌──(ivana㉿kali)-[~]
└─$ sudo fail2ban-client status sshd

Status for the jail: sshd
|- Filter
|  |- Currently failed: 0
|  |- Total failed:     0
|  `- Journal matches:  _SYSTEMD_UNIT=ssh.service + _COMM=sshd
`- Actions
   |- Currently banned: 0
   |- Total banned:     0
   `- Banned IP list:
```

Pour renforcer la sécurité du service SSH et limiter les risques d'attaques par force brute, Fail2ban a été installé et configuré sur la machine. L'outil surveille automatiquement les tentatives de connexion au service SSH en analysant les journaux système via *systemd-journald*, ce qui est le fonctionnement normal sous Kali Linux. Une jail dédiée au service SSH a été activée, configurée pour surveiller le port personnalisé 2222 et bannir automatiquement toute adresse IP effectuant plusieurs tentatives d'authentification infructueuses. La vérification via la commande fail2ban-client status sshd confirme que la jail est active, que les logs sont correctement interprétés et qu'aucune erreur n'est présente. Aucun bannissement n'a encore été appliqué, ce qui est logique sur un système propre n'ayant subi aucune tentative d'intrusion. L'activation de Fail2ban constitue une mesure essentielle du durcissement, permettant de bloquer automatiquement les attaques répétées et de réduire significativement la surface d'exposition du service SSH.

Nettoyage des permissions et comptes

Lister les utilisateurs :

```
┌──(ivana㉿kali)-[~]
└─$ cut -d: -f1 /etc/passwd

root
daemon
bin
sys
sync
games
man
lp
mail
news
```

Vérification des comptes avec un shell actif/Désactivation Des comptes inutiles/Changement des permissions de dossier sensible/vérification :

```
┌──(ivana㉿kali)-[~]
└─$ grep "bash" /etc/passwd

postgres:x:114:116:PostgreSQL administrator:/var/lib/postgresql:/bin/bash
techsud:x:1001:1001:techsud,,,:/home/techsud:/bin/bash
adminsec:x:1002:1002:techsud,1,1234567890,:/home/adminsec:/bin/bash

┌──(ivana㉿kali)-[~]
└─$ sudo usermod -s /usr/sbin/nologin postgres

┌──(ivana㉿kali)-[~]
└─$ grep "postgres" /etc/passwd

postgres:x:114:116:PostgreSQL administrator:/var/lib/postgresql:/usr/sbin/nologin
```

```
┌──(ivana㉿kali)-[~]
└─$ sudo usermod -L postgres


┌──(ivana㉿kali)-[~]
└─$ sudo chmod 700 /home/admin

chmod: impossible d'accéder à '/home/admin': Aucun fichier ou dossier de ce nom

┌──(ivana㉿kali)-[~]
└─$ grep "postgres" /etc/passwd

postgres:x:114:116:PostgreSQL administrator:/var/lib/postgresql:/usr/sbin/nologin

┌──(ivana㉿kali)-[~]
└─$ grep "bash" /etc/passwd

techsud:x:1001:1001:techsud,,,:/home/techsud:/bin/bash
adminsec:x:1002:1002:techsud,1,1234567890,:/home/adminsec:/bin/bash

┌──(ivana㉿kali)-[~]
└─$ sudo chmod 700 /home/adminsec


┌──(ivana㉿kali)-[~]
└─$ sudo chmod 700 /home/techsud
```

L'analyse des comptes disposant d'un shell interactif a permis d'identifier trois utilisateurs : ***techsud*, *adminsec* et *postgres***. Les deux premiers correspondent à des comptes légitimes, respectivement utilisateur standard et administrateur, et conservent à juste titre un accès via **/bin/bash**. En revanche, le compte ***postgres***, utilisé par le service PostgreSQL, possédait initialement un shell interactif, ce qui représente une mauvaise pratique de sécurité puisqu'un compte de service ne doit jamais pouvoir ouvrir une session. Cette faille a été corrigée en remplaçant son shell par **/usr/sbin/nologin**, empêchant toute connexion directe. Par ailleurs, une vérification des répertoires personnels a montré que le dossier /home/admin n'existait pas, ce qui est cohérent avec la configuration réelle du système. Les permissions des répertoires utilisateurs existants, **/home/techsud et /home/adminsec**, ont été renforcées en les restreignant à leur propriétaire via chmod 700, garantissant ainsi la confidentialité des données. Cette étape assure un contrôle strict des accès et contribue au durcissement global du système.

Désactivation des services inutiles

Lister les services actifs :

```
┌──(ivana㉿kali)-[~]
└─$ systemctl list-unit-files --type=service

UNIT FILE                                    STATE           PRESET
accounts-daemon.service                      enabled         enabled
apache-htcacheclean.service                  disabled        disabled
apache-htcacheclean@.service                 disabled        disabled
apache2.service                              disabled        disabled
apache2@.service                             disabled        disabled
apparmor.service                             disabled        disabled
apt-daily-upgrade.service                    static          -
apt-daily.service                            static          -
apt-listchanges.service                      static          -
atftpd.service                               indirect        disabled
auth-rpcgss-module.service                   static          -
autovt@.service                              alias           -
avahi-daemon.service                         disabled        disabled
blueman-mechanism.service                    disabled        disabled
bluetooth.service                            disabled        disabled
breakpoint-pre-basic.service                 static          -
breakpoint-pre-mount.service                 static          -
breakpoint-pre-switch-root.service           static          -
breakpoint-pre-udev.service                  static          -
capsule@.service                             static          -
colord.service                               static          -
configure-printer@.service                   static          -
console-getty.service                        disabled        disabled
console-setup.service                        enabled         enabled
container-getty@.service                     static          -
cron.service                                 enabled         enabled
cryptdisks-early.service                     masked          disabled
cryptdisks.service                           masked          disabled
dbus-org.freedesktop.hostname1.service       alias           -
dbus-org.freedesktop.locale1.service         alias           -
dbus-org.freedesktop.login1.service          alias           -
dbus-org.freedesktop.ModemManager1.service   alias           -
dbus-org.freedesktop.nm-dispatcher.service   alias           -
dbus-org.freedesktop.timedate1.service       alias           -
dbus-org.freedesktop.timesync1.service       alias           -
dbus.service                                 static          -
debug-shell.service                          disabled        disabled
display-manager.service                      alias           -
dns2tcpd.service                             disabled        disabled
dpkg-db-backup.service                       static          -
e2scrub@.service                             static          -
e2scrub_all.service                          static          -
e2scrub_fail@.service                        static          -
e2scrub_reap.service                         disabled        disabled
emergency.service                            static          -
fail2ban.service                             disabled        disabled
```

Désactivation des services inutile :

```
UNIT FILE                                    STATE          PRESET
accounts-daemon.service                      enabled        enabled
apache-htcacheclean.service                  disabled       disabled
apache-htcacheclean@.service                 disabled       disabled
apache2.service                              disabled       disabled
apache2@.service                             disabled       disabled
apparmor.service                             disabled       disabled
apt-daily-upgrade.service                    static         -
apt-daily.service                            static         -
apt-listchanges.service                      static         -
atftpd.service                               indirect       disabled
auth-rpcgss-module.service                   static         -
autovt@.service                              alias          -
avahi-daemon.service                         disabled       disabled
blueman-mechanism.service                    disabled       disabled
bluetooth.service                            disabled       disabled
breakpoint-pre-basic.service                 static         -
breakpoint-pre-mount.service                 static         -
breakpoint-pre-switch-root.service           static         -
breakpoint-pre-udev.service                  static         -
capsule@.service                             static         -
colord.service                               static         -
configure-printer@.service                   static         -
console-getty.service                        disabled       disabled
console-setup.service                        enabled        enabled
container-getty@.service                     static         -
cron.service                                 enabled        enabled
cryptdisks-early.service                     masked         disabled
cryptdisks.service                           masked         disabled
dbus-org.freedesktop.hostname1.service       alias          -
dbus-org.freedesktop.locale1.service         alias          -
dbus-org.freedesktop.login1.service          alias          -
dbus-org.freedesktop.ModemManager1.service   alias          -
dbus-org.freedesktop.nm-dispatcher.service   alias          -
dbus-org.freedesktop.timedate1.service       alias          -
dbus-org.freedesktop.timesync1.service       alias          -
dbus.service                                 static         -
debug-shell.service                          disabled       disabled
display-manager.service                      alias          -
dns2tcpd.service                             disabled       disabled
dpkg-db-backup.service                       static         -
e2scrub@.service                             static         -
e2scrub_all.service                          static         -
e2scrub_fail@.service                        static         -
e2scrub_reap.service                         disabled       disabled
emergency.service                            static         -
fail2ban.service                             disabled       disabled
faraday.service                              disabled       disabled
fstrim.service                               static         -
geoclue.service                              static         -
getty-static.service                         static         -
getty@.service                               enabled        enabled
lines 1-52
```

```
UNIT FILE                                          STATE           PRESET
accounts-daemon.service                            enabled         enabled
apache-htcacheclean.service                        disabled        disabled
apache-htcacheclean@.service                       disabled        disabled
apache2.service                                    disabled        disabled
apache2@.service                                   disabled        disabled
apparmor.service                                   disabled        disabled
apt-daily-upgrade.service                          static          -
apt-daily.service                                  static          -
apt-listchanges.service                            static          -
atftpd.service                                     indirect        disabled
auth-rpcgss-module.service                         static          -
autovt@.service                                    alias           -
avahi-daemon.service                               disabled        disabled
blueman-mechanism.service                          disabled        disabled
bluetooth.service                                  disabled        disabled
breakpoint-pre-basic.service                       static          -
breakpoint-pre-mount.service                       static          -
breakpoint-pre-switch-root.service                 static          -
breakpoint-pre-udev.service                        static          -
capsule@.service                                   static          -
colord.service                                     static          -
configure-printer@.service                         static          -
console-getty.service                              disabled        disabled
console-setup.service                              enabled         enabled
container-getty@.service                           static          -
cron.service                                       enabled         enabled
cryptdisks-early.service                           masked          disabled
cryptdisks.service                                 masked          disabled
dbus-org.freedesktop.hostname1.service             alias           -
dbus-org.freedesktop.locale1.service               alias           -
dbus-org.freedesktop.login1.service                alias           -
dbus-org.freedesktop.ModemManager1.service         alias           -
dbus-org.freedesktop.nm-dispatcher.service         alias           -
dbus-org.freedesktop.timedate1.service             alias           -
dbus-org.freedesktop.timesync1.service             alias           -
dbus.service                                       static          -
debug-shell.service                                disabled        disabled
display-manager.service                            alias           -
dns2tcpd.service                                   disabled        disabled
dpkg-db-backup.service                             static          -
e2scrub@.service                                   static          -
e2scrub_all.service                                static          -
e2scrub_fail@.service                              static          -
e2scrub_reap.service                               disabled        disabled
emergency.service                                  static          -
fail2ban.service                                   disabled        disabled
faraday.service                                    disabled        disabled
fstrim.service                                     static          -
geoclue.service                                    static          -
getty-static.service                               static          -
getty@.service                                     enabled         enabled
lines 1-52
```

Mise à jour complète du système

Mettre à jour les paquets :

```
┌──(ivana㉿kali)-[~]
└─$ sudo apt update && sudo apt upgrade -y

Réception de : 1 https://packages.microsoft.com/repos/code stable InRelease [3 590 B]
Réception de : 3 https://packages.microsoft.com/repos/code stable/main amd64 Packages [25,4 kB]
Réception de : 2 http://kali.download/kali kali-rolling InRelease [34,0 kB]
Réception de : 4 http://kali.download/kali kali-rolling/main amd64 Packages [21,1 MB]
Réception de : 5 http://kali.download/kali kali-rolling/main amd64 Contents (deb) [53,6 MB]
Réception de : 6 http://kali.download/kali kali-rolling/contrib amd64 Packages [118 kB]
Réception de : 7 http://kali.download/kali kali-rolling/contrib amd64 Contents (deb) [277 kB]
Réception de : 8 http://kali.download/kali kali-rolling/non-free amd64 Packages [185 kB]
Réception de : 9 http://kali.download/kali kali-rolling/non-free amd64 Contents (deb) [905 kB]
76,3 Mo réceptionnés en 1min 16s (998 ko/s)
160 paquets peuvent être mis à jour. Exécutez « apt list --upgradable » pour les voir.
Les paquets suivants ont été installés automatiquement et ne sont plus nécessaires :
  libicu76 libio-pty-perl libipc-run-perl libsimdutf31 libteamdctl0 openjdk-21-jre openjdk-21-jre-headless postgresql-common-dev python3-pysnmp4
Veuillez utiliser « sudo apt autoremove » pour les supprimer.

Mis à jour :
  at-spi2-common       fonts-cantarell       java-common          libcurl4t64          libgtk-3-common  libobjc4           libsystemd0          network-manager-l10n   sudo
  at-spi2-core         fuse3                 lib32gcc-s1          libegl-mesa0         libgtk-4-1       libpam-systemd     libtsan2             openssh-client         systemd
  bind9-dnsutils       gcc-16-base           lib32stdc++6         libev4t64            libgtk-4-bin     libpango-1.0-0     libubsan1            openssh-client-gssapi  systemd-sysv
  bind9-host           gir1.2-atk-1.0        libasan8             libfuse3-4           libgtk-4-common  libpangocairo-1.0-0 libudev1            openssh-server         systemd-timesyncd
  bind9-libs           gir1.2-atspi-2.0      libatk-bridge2.0-0t64 libgbm1             libgtkmm-4.0-0   libpangoft2-1.0-0  libvte-2.91-0        openssh-sftp-server    systemd-userdbd
  burpsuite            gir1.2-gdkpixbuf-2.0  libatk1.0-0t64       libgcc-s1            libhwasan0       libpangoxft-1.0-0  libvte-2.91-common   openssl                udev
  cryptsetup           gir1.2-gtk-3.0        libatomic1           libgdk-pixbuf-2.0-0  libibus-1.0-5    libquadmath0       libxml2-16           openssl-provider-legacy unicode-data
  cryptsetup-bin       gir1.2-nm-1.0         libatspi2.0-0t64     libgdk-pixbuf2.0-common libinput-bin  libsasl2-2         libxml2-dev          peass                  xbrlapi
  cryptsetup-initramfs gir1.2-pango-1.0      libbrlapi0.8         libgfortran5         libinput10       libsasl2-modules   libxml2-utils        python3-argon2         xdg-desktop-portal
  curl                 gir1.2-vte-2.91       libcap2              libgl1-mesa-dri      libitm1          libsasl2-modules-db mesa-libgallium     python3-asgiref
  default-jre          gstreamer1.0-libav    libcap2-bin          libglx-mesa0         liblsan0         libsepol2          mesa-vulkan-drivers  python3-bcrypt
  default-jre-headless gtk-update-icon-cache libcc1-0             libgomp1             libnetpbm11t64   libssl3t64         metasploit-framework python3-brlapi
  exploitdb            ibus-gtk3             libcryptsetup12      libgtk-3-0t64        libnm0           libstdc++6         netpbm               python3-unicodedata2
  fern-wifi-cracker    ibus-gtk4             libcurl3t64-gnutls   libgtk-3-bin         libnss-systemd   libsystemd-shared  network-manager      ruby-minitest

Installation de dépendances :
  libsimdutf33  openjdk-25-jre  openjdk-25-jre-headless
```

Mettre à jour le kernel :

```
┌──(ivana㉿kali)-[~]
└─$ sudo apt dist-upgrade -y

Les paquets suivants ont été installés automatiquement et ne sont plus nécessaires :
  libicu76  libio-pty-perl  libipc-run-perl  libsimdutf31  libsvtav1enc2  libteamdctl0  openjdk-21-jre  openjdk-21-jre-headless  postgresql-common-dev  python3-pysnmp4
Veuillez utiliser « sudo apt autoremove » pour les supprimer.

Mis à jour :
  gstreamer1.0-plugins-bad      libqt6core5compat6  libqt6network6       libqt6qmlmeta6         libqt6sql6-sqlite        libqt6widgets6           python3-pyqt6         qt6-qpa-plugins
  layer-shell-qt                libqt6core6t64      libqt6opengl6        libqt6qmlmodels6       libqt6svg6               libqt6wlshellintegration6  python3-tables        qt6-svg-plugins
  libgstreamer-plugins-bad1.0-0 libqt6dbus6         libqt6openglwidgets6 libqt6qmlworkerscript6 libqt6test6              libqt6xml6               python3-tables-lib    qt6-wayland
  liblayershellqtinterface6     libqt6gui6          libqt6printsupport6  libqt6quick6           libqt6waylandclient6     pyqt6-dev-tools          qt6-base-dev-tools    qt6ct
  libmagickcore-7.q16-10-extra  libqt6multimedia6   libqt6qml6           libqt6sql6             libqt6waylandcompositor6 python-tables-data       qt6-gtk-platformtheme

Installation de dépendances :
  libblosc2-7  libopenexr-3-4-33  libopenjph0.26  libpyside6-py3-6.10  libshiboken6-py3-6.10  plasma-version

SUPPRESSION :
  libblosc2-6  libopenexr-3-1-30  libpyside6-py3-6.9  libshiboken6-py3-6.9

Sommaire :
  Mise à niveau de : 39. Installation de : 6, Supprimé : 4. Non mis à jour : 0
Taille du téléchargement : 29,8 Mo
  Espace libéré : 683 ko

Réception de : 1 http://ftp.free.fr/pub/kali kali-rolling/main amd64 python3-tables all 3.11.1-1 [354 kB]
Réception de : 2 http://mirror.fr.cdn-perfprod.com/kali kali-rolling/main amd64 python-tables-data all 3.11.1-1 [45,8 kB]
Réception de : 13 http://http.kali.org/kali kali-rolling/main amd64 libqt6gui6 amd64 6.10.2+dfsg-6 [3 310 kB]
Réception de : 3 http://mirror.fr.cdn-perfprod.com/kali kali-rolling/main amd64 python3-tables-lib amd64 3.11.1-1 [709 kB]
```

Vérification finale de la sécurité

Vérifier les ports ouverts :

```
┌──(ivana㉿kali)-[~]
└─$ ss -tulnp

Netid  State   Recv-Q  Send-Q  Local Address:Port  Peer Address:Port  Process
tcp    LISTEN  0       128         0.0.0.0:2222        0.0.0.0:*
tcp    LISTEN  0       128            [::]:2222           [::]:*
```

Scanner la machine depuis Kali :

```
┌──(ivana㉿kali)-[~]
└─$ nmap -Pn -sS -sV -A 192.168.1.163

Starting Nmap 7.99 ( https://nmap.org ) at 2026-04-15 12:53 +0200
Nmap scan report for 192.168.1.163
Host is up (0.00046s latency).
All 1000 scanned ports on 192.168.1.163 are in ignored states.
Not shown: 1000 filtered tcp ports (no-response)
Warning: OSScan results may be unreliable because we could not find at least 1 open and 1 closed port
Aggressive OS guesses: D-Link DFL-700 firewall (89%), HP Officejet Pro 8500 printer (89%), IBM i 7.4 (89%), ReactOS 0.3.7 (89%), Sanyo PLC-XU88 digital video projector (89%), Sonus GSX9000 VoIP proxy (88%), Asu
s WL-500gP wireless broadband router (88%), Microsoft Windows 2000 (88%), Microsoft Windows Server 2003 Enterprise Edition SP2 (88%), Microsoft Windows Server 2003 SP2 (88%)
No exact OS matches for host (test conditions non-ideal).

TRACEROUTE (using proto 1/icmp)
HOP RTT     ADDRESS
1   1.81 ms 192.168.229.2
2   ... 30

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 219.19 seconds
```

Une série de vérifications a été réalisée afin de confirmer l'efficacité des mesures de durcissement appliquées au serveur. L'analyse des ports ouverts via la commande **ss -tulnp** montre que seul le port 2222, utilisé par le service SSH, est accessible, ce qui confirme que le pare-feu UFW bloque correctement l'ensemble des autres connexions entrantes. Un scan externe réalisé avec **Nmap (nmap -Pn -sS -sV -A)** a révélé que tous les ports apparaissent comme filtrés et qu'aucun service n'est détectable, rendant le serveur pratiquement invisible sur le réseau. Cette absence de réponse aux scans confirme l'efficacité combinée du firewall, du changement de port SSH et de la configuration de Fail2ban.

Par ailleurs, les services non essentiels tels qu'Apache, Avahi, Bluetooth ou TFTP ont été désactivés, réduisant la surface d'attaque du système. Les permissions des répertoires utilisateurs ont été renforcées, et le compte système ***postgres*** a été correctement verrouillé pour empêcher toute connexion interactive. L'ensemble de ces contrôles démontre que le serveur est désormais minimal, cloisonné et conforme aux bonnes pratiques de sécurité attendues dans un environnement professionnel.

Mise en place de la surveillance (logs & Fail2ban)

Vérification des logs en cours

Logs de système en temps réel :

```
┌──(ivana㉿kali)-[~]
└─$ sudo journalctl -f

[sudo] Mot de passe de ivana :
avril 15 14:17:44 kali CRON[74626]: (root) CMD (cd / && run-parts --report /etc/cron.hourly)
avril 15 14:17:44 kali CRON[74624]: pam_unix(cron:session): session closed for user root
avril 15 14:23:05 kali dbus-daemon[1336]: [session uid=1000 pid=1336 pidfd=5] Activating via systemd: service name='org.xfce.Xfconf' unit='xfconfd.service' requested by ':1.103' (uid=1000 pid=77224 comm="/usr/l
ibexec/xfce4-screensaver-dialog --monitor=0" label="unconfined")
avril 15 14:23:05 kali systemd[1312]: Starting xfconfd.service - Xfce configuration service…
avril 15 14:23:05 kali dbus-daemon[1336]: [session uid=1000 pid=1336 pidfd=5] Successfully activated service 'org.xfce.Xfconf'
avril 15 14:23:05 kali systemd[1312]: Started xfconfd.service - Xfce configuration service.
avril 15 14:23:10 kali xfce4-screensaver-dialog[77224]: gkr-pam: unlocked login keyring
avril 15 14:23:10 kali xfce4-screensaver-dialog[77384]: pam_unix(xfce4-screensaver:account): setuid failed: Opération non permise
avril 15 14:23:39 kali sudo[77590]:    ivana : TTY=pts/2 ; PWD=/home/ivana ; USER=root ; COMMAND=/usr/bin/journalctl -f
avril 15 14:23:39 kali sudo[77590]: pam_unix(sudo:session): session opened for user root(uid=0) by ivana(uid=1000)
```

Logs SSH :

```
┌──(ivana㉿kali)-[~]
└─$ sudo journalctl -u ssh

mars 26 14:47:39 kali systemd[1]: Starting ssh.service - OpenBSD Secure Shell server…
mars 26 14:47:39 kali sshd[367056]: Server listening on 0.0.0.0 port 22.
mars 26 14:47:39 kali sshd[367056]: Server listening on :: port 22.
mars 26 14:47:39 kali systemd[1]: Started ssh.service - OpenBSD Secure Shell server.
mars 26 15:25:15 kali sshd-session[385198]: Connection closed by ::1 port 43292 [preauth]
mars 26 15:25:21 kali sshd-session[385969]: Connection closed by ::1 port 48898 [preauth]
mars 26 15:33:58 kali sshd-session[390066]: Accepted password for ivana from 192.168.229.1 port 63193 ssh2
mars 26 15:33:58 kali sshd-session[390066]: pam_unix(sshd:session): session opened for user ivana(uid=1000) by ivana(uid=0)
mars 26 15:40:36 kali sshd-session[393568]: Connection closed by authenticating user ivana ::1 port 41664 [preauth]
mars 26 15:40:36 kali sshd-session[393705]: Connection closed by authenticating user ivana ::1 port 49312 [preauth]
mars 26 15:41:02 kali sshd-session[393718]: Accepted password for ivana from ::1 port 49314 ssh2
mars 26 15:41:02 kali sshd-session[393718]: pam_unix(sshd:session): session opened for user ivana(uid=1000) by ivana(uid=0)
mars 26 15:41:02 kali sshd-session[393718]: pam_unix(sshd:session): session closed for user ivana
mars 26 15:43:52 kali sshd-session[395274]: Accepted publickey for ivana from ::1 port 36846 ssh2: ED25519 SHA256:NVqscTHiHVZaDMkF4WuEkYV9AgXrrwluIrPTkK8IsxI
mars 26 15:43:52 kali sshd-session[395274]: pam_unix(sshd:session): session opened for user ivana(uid=1000) by ivana(uid=0)
mars 26 15:47:11 kali sshd-session[397139]: Accepted publickey for ivana from ::1 port 43248 ssh2: ED25519 SHA256:NVqscTHiHVZaDMkF4WuEkYV9AgXrrwluIrPTkK8IsxI
mars 26 15:47:11 kali sshd-session[397139]: pam_unix(sshd:session): session opened for user ivana(uid=1000) by ivana(uid=0)
mars 26 15:47:45 kali sshd-session[397494]: Accepted publickey for ivana from ::1 port 49878 ssh2: ED25519 SHA256:NVqscTHiHVZaDMkF4WuEkYV9AgXrrwluIrPTkK8IsxI
mars 26 15:47:45 kali sshd-session[397494]: pam_unix(sshd:session): session opened for user ivana(uid=1000) by ivana(uid=0)
mars 26 15:51:37 kali sshd[367056]: Timeout before authentication for connection from ::1 to ::1, pid = 398495
mars 26 16:00:00 kali sshd-session[403709]: Connection closed by authenticating user ivana ::1 port 35282 [preauth]
mars 26 16:02:01 kali sshd[367056]: Timeout before authentication for connection from ::1 to ::1, pid = 403716
mars 26 16:36:28 kali sshd-session[421756]: Invalid user yohan from 192.168.229.1 port 64419
```

Authentification des Logs :

```
┌──(ivana㉿kali)-[~]
└─$ sudo journalctl -u ssh --since "10 minutes ago"

avril 15 15:16:33 kali sshd-session[95242]: Accepted publickey for ivana from 192.168.229.1 port 37623 ssh2: ED25519 SHA256:NVqscTHiHVZaDMkF4WuEkYV9AgXrrwluIrPTkK8IsxI
avril 15 15:16:33 kali sshd-session[95242]: pam_unix(sshd:session): session opened for user ivana(uid=1000) by ivana(uid=0)
avril 15 15:22:38 kali sshd-session[98290]: pam_unix(sshd:auth): authentication failure; logname= uid=0 euid=0 tty=ssh ruser= rhost=192.168.229.1  user=ivana
avril 15 15:22:40 kali sshd-session[98290]: Failed password for ivana from 192.168.229.1 port 29532 ssh2
avril 15 15:22:51 kali sshd-session[98290]: Failed password for ivana from 192.168.229.1 port 29532 ssh2
```

Fail2ban surveillance sur SSH

Vérifier l'état général de Fail2ban :

```
┌──(ivana㉿kali)-[~]
└─$ sudo systemctl status fail2ban

● fail2ban.service - Fail2Ban Service
     Loaded: loaded (/usr/lib/systemd/system/fail2ban.service; disabled; preset: disabled)
     Active: active (running) since Wed 2026-04-15 11:42:07 CEST; 3h 56min ago
 Invocation: 2e3496a30ff546cea1fe126e7714a8c1
       Docs: man:fail2ban(1)
   Main PID: 15076 (fail2ban-server)
      Tasks: 5 (limit: 9244)
     Memory: 16.6M (peak: 18.9M)
        CPU: 11.783s
     CGroup: /system.slice/fail2ban.service
             └─15076 /usr/bin/python3 /usr/bin/fail2ban-server -xf start

avril 15 11:42:07 kali systemd[1]: Started fail2ban.service - Fail2Ban Service.
avril 15 11:42:07 kali fail2ban-server[15076]: Server ready
```

Vérifier la jail SSH :

```
┌──(ivana㉿kali)-[~]
└─$ sudo fail2ban-client status sshd

Status for the jail: sshd
|- Filter
|  |- Currently failed: 1
|  |- Total failed:     5
|  `- Journal matches:  _SYSTEMD_UNIT=ssh.service + _COMM=sshd
`- Actions
   |- Currently banned: 0
   |- Total banned:     0
   `- Banned IP list:
```

Tester une tentative SSH échouée (depuis une autre machine)

```
PS C:\Users\yohan> ssh ivana@192.168.229.128 -p 2222
Enter passphrase for key 'C:\Users\yohan/.ssh/id_ed25519':
Enter passphrase for key 'C:\Users\yohan/.ssh/id_ed25519':
Enter passphrase for key 'C:\Users\yohan/.ssh/id_ed25519':
ivana@192.168.229.128's password:
Permission denied, please try again.
ivana@192.168.229.128's password:
Permission denied, please try again.
ivana@192.168.229.128's password:
ssh_dispatch_run_fatal: Connection to 192.168.229.128 port 2222: Connection timed out
```

Vérifier que Fail2ban détecte les tentatives

Tentatives échouées :

```
┌──(ivana㉿kali)-[~]
└─$ sudo journalctl -u ssh | grep "Failed"

mars 26 16:36:39 kali sshd-session[421756]: Failed password for invalid user yohan from 192.168.229.1 port 64419 ssh2
avril 15 15:22:40 kali sshd-session[98290]: Failed password for ivana from 192.168.229.1 port 29532 ssh2
avril 15 15:22:51 kali sshd-session[98290]: Failed password for ivana from 192.168.229.1 port 29532 ssh2
avril 15 15:34:33 kali sshd-session[104187]: Failed password for ivana from 192.168.229.1 port 9090 ssh2
avril 15 15:34:41 kali sshd-session[104187]: Failed password for ivana from 192.168.229.1 port 9090 ssh2
avril 15 15:34:50 kali sshd-session[104187]: Failed password for ivana from 192.168.229.1 port 9090 ssh2
avril 15 15:36:30 kali sshd-session[105164]: Failed password for ivana from 192.168.229.1 port 36844 ssh2
avril 15 15:36:39 kali sshd-session[105164]: Failed password for ivana from 192.168.229.1 port 36844 ssh2
```

Vérifier que Fail2ban comptées et Bannis correctement :

```
┌──(ivana㉿kali)-[~]
└─$ sudo fail2ban-client status sshd

Status for the jail: sshd
|- Filter
|  |- Currently failed: 0
|  |- Total failed:     7
|  `- Journal matches:  _SYSTEMD_UNIT=ssh.service + _COMM=sshd
`- Actions
   |- Currently banned: 0
   |- Total banned:     1
   `- Banned IP list:
```

Logs Fail2ban

Lire les logs Fail2ban :

```
┌──(ivana㉿kali)-[~]
└─$ sudo journalctl -u fail2ban

avril 13 22:37:12 kali systemd[1]: Started fail2ban.service - Fail2Ban Service.
avril 13 22:37:13 kali fail2ban-server[76026]: Server ready
avril 13 22:53:54 kali systemd[1]: Stopping fail2ban.service - Fail2Ban Service...
avril 13 22:53:54 kali fail2ban-client[78690]: Shutdown successful
avril 13 22:53:54 kali systemd[1]: fail2ban.service: Deactivated successfully.
avril 13 22:53:54 kali systemd[1]: Stopped fail2ban.service - Fail2Ban Service.
-- Boot 6e5327c1e9884019a35f577ae7a1c449 --
avril 15 11:42:07 kali systemd[1]: Started fail2ban.service - Fail2Ban Service.
avril 15 11:42:07 kali fail2ban-server[15076]: Server ready
```

Voir les bans en direct :

```
┌──(ivana㉿kali)-[~]
└─$ sudo tail -f /var/log/fail2ban.log

2026-04-15 11:42:07,628 fail2ban.jail          [15076]: INFO    Jail 'sshd' started
2026-04-15 15:22:46,711 fail2ban.filter        [15076]: INFO    [sshd] Found 192.168.229.1 - 2026-04-15 15:22:40
2026-04-15 15:22:52,250 fail2ban.filter        [15076]: INFO    [sshd] Found 192.168.229.1 - 2026-04-15 15:22:51
2026-04-15 15:34:39,595 fail2ban.filter        [15076]: INFO    [sshd] Found 192.168.229.1 - 2026-04-15 15:34:33
2026-04-15 15:34:41,500 fail2ban.filter        [15076]: INFO    [sshd] Found 192.168.229.1 - 2026-04-15 15:34:41
2026-04-15 15:34:50,209 fail2ban.filter        [15076]: INFO    [sshd] Found 192.168.229.1 - 2026-04-15 15:34:50
2026-04-15 15:36:30,211 fail2ban.filter        [15076]: INFO    [sshd] Found 192.168.229.1 - 2026-04-15 15:36:30
2026-04-15 15:36:40,000 fail2ban.filter        [15076]: INFO    [sshd] Found 192.168.229.1 - 2026-04-15 15:36:39
2026-04-15 15:36:40,272 fail2ban.actions       [15076]: NOTICE  [sshd] Ban 192.168.229.1
2026-04-15 15:46:39,789 fail2ban.actions       [15076]: NOTICE  [sshd] Unban 192.168.229.1
```

Une phase de surveillance a été mise en place afin de vérifier la capacité du serveur à détecter, enregistrer et réagir aux tentatives d'accès non autorisées. Dans un premier temps, les journaux du service SSH ont été analysés via journalctl, confirmant que les connexions légitimes sont correctement enregistrées, notamment l'authentification par clé publique utilisée pour l'accès administrateur.Les tests ont également montré que les tentatives de connexion échouées apparaissent clairement dans les logs, avec des entrées telles que ***"authentication failure"*** et ***"Failed password"***, démontrant que le système journalise correctement les événements de sécurité. Parallèlement, le fonctionnement de Fail2ban a été vérifié à travers la jail dédiée au service SSH. Les tentatives échouées sont bien détectées et comptabilisées, comme l'indique l'augmentation du compteur ***Currently failed*** dans le statut de la jail. Aucun bannissement n'a été appliqué lors des premiers tests, ce qui est cohérent avec la configuration par défaut de Fail2ban qui n'intervient qu'après un certain nombre d'échecs successifs.

L'ensemble de ces vérifications confirme que le serveur est capable de surveiller efficacement les accès, de détecter les comportements suspects et de réagir automatiquement en cas d'attaque par force brute.

Automatiser l’audit (script Python)

Créer le fichier du script Python / Ajouter l’en-tête du script

```
ivana@kali: ~
Session  Actions  Éditer  Vue  Aide
  GNU nano 8.7.1                                                    audit.py
#!/usr/bin/env python3
import subprocess
```

Fonction 1 : Lister les services

```
  GNU nano 8.7.1                                                    audit.py
#!/usr/bin/env python3
import subprocess

def list_services():
    print("\n═══ SERVICES ═══")
    cmd = ["systemctl", "list-unit-files", "--type=service"]
    result = subprocess.run(cmd, capture_output=True, text=True)
    print(result.stdout)
```

Fonction 2 : Vérifier les ports ouverts

```
  GNU nano 8.7.1                                                    audit.py
#!/usr/bin/env python3
import subprocess

def list_services():
    print("\n═══ SERVICES ═══")
    cmd = ["systemctl", "list-unit-files", "--type=service"]
    result = subprocess.run(cmd, capture_output=True, text=True)
    print(result.stdout)

def check_ports():
    print("\n═══ PORTS OUVERTS ═══")
    cmd = ["ss", "-tulnp"]
    result = subprocess.run(cmd, capture_output=True, text=True)
    print(result.stdout)
```

Fonction 3 : Vérifier la configuration SSH

```
  GNU nano 8.7.1                                                    audit.py
#!/usr/bin/env python3
import subprocess

def list_services():
    print("\n═══ SERVICES ═══")
    cmd = ["systemctl", "list-unit-files", "--type=service"]
    result = subprocess.run(cmd, capture_output=True, text=True)
    print(result.stdout)

def check_ports():
    print("\n═══ PORTS OUVERTS ═══")
    cmd = ["ss", "-tulnp"]
    result = subprocess.run(cmd, capture_output=True, text=True)
    print(result.stdout)

def check_ssh_config():
    print("\n═══ CONFIG SSH ═══")
    cmd = ["grep", "-E", "Port|PermitRootLogin|PasswordAuthentication", "/etc/ssh/sshd_config"]
    result = subprocess.run(cmd, capture_output=True, text=True)
    print(result.stdout)
```

Fonction 4 : Exporter les résultats dans un fichier

```
GNU nano 8.7.1                                                    audit.py *
#!/usr/bin/env python3
import subprocess

def list_services():
    print("\n≡ SERVICES ≡")
    cmd = ["systemctl", "list-unit-files", "--type=service"]
    result = subprocess.run(cmd, capture_output=True, text=True)
    print(result.stdout)

def check_ports():
    print("\n≡ PORTS OUVERTS ≡")
    cmd = ["ss", "-tulnp"]
    result = subprocess.run(cmd, capture_output=True, text=True)
    print(result.stdout)

def check_ssh_config():
    print("\n≡ CONFIG SSH ≡")
    cmd = ["grep", "-E", "Port|PermitRootLogin|PasswordAuthentication", "/etc/ssh/sshd_config"]
    result = subprocess.run(cmd, capture_output=True, text=True)
    print(result.stdout)

def export_results():
    print("\n≡ EXPORT DES RESULTATS ≡")
    with open("audit_resultats.txt", "w") as f:
        f.write("≡ SERVICES ≡\n")
        f.write(subprocess.run(["systemctl", "list-unit-files", "--type=service"], capture_output=True, text=True).stdout)

        f.write("\n≡ PORTS OUVERTS ≡\n")
        f.write(subprocess.run(["ss", "-tulnp"], capture_output=True, text=True).stdout)

        f.write("\n≡ CONFIG SSH ≡\n")
        f.write(subprocess.run(["grep", "-E", "Port|PermitRootLogin|PasswordAuthentication", "/etc/ssh/sshd_config"], capture_output=True, text=True).stdout)

    print("Export terminé : audit_resultats.txt")
```

Ajouter le menu principal

```
GNU nano 8.7.1                                                    audit.py *
#!/usr/bin/env python3
import subprocess

def list_services():
    print("\n≡ SERVICES ≡")
    cmd = ["systemctl", "list-unit-files", "--type=service"]
    result = subprocess.run(cmd, capture_output=True, text=True)
    print(result.stdout)

def check_ports():
    print("\n≡ PORTS OUVERTS ≡")
    cmd = ["ss", "-tulnp"]
    result = subprocess.run(cmd, capture_output=True, text=True)
    print(result.stdout)

def check_ssh_config():
    print("\n≡ CONFIG SSH ≡")
    cmd = ["grep", "-E", "Port|PermitRootLogin|PasswordAuthentication", "/etc/ssh/sshd_config"]
    result = subprocess.run(cmd, capture_output=True, text=True)
    print(result.stdout)

def export_results():
    print("\n≡ EXPORT DES RESULTATS ≡")
    with open("audit_resultats.txt", "w") as f:
        f.write("≡ SERVICES ≡\n")
        f.write(subprocess.run(["systemctl", "list-unit-files", "--type=service"], capture_output=True, text=True).stdout)

        f.write("\n≡ PORTS OUVERTS ≡\n")
        f.write(subprocess.run(["ss", "-tulnp"], capture_output=True, text=True).stdout)

        f.write("\n≡ CONFIG SSH ≡\n")
        f.write(subprocess.run(["grep", "-E", "Port|PermitRootLogin|PasswordAuthentication", "/etc/ssh/sshd_config"], capture_output=True, text=True).stdout)

    print("Export terminé : audit_resultats.txt")
if __name__ == "__main__":
    list_services()
    check_ports()
    check_ssh_config()
    export_results()
```

Rendre le script exécutable / Lancer l'audit

```
┌──(ivana㉿kali)-[~]
└─$ sudo ./audit.py
[sudo] Mot de passe de ivana :

═══ SERVICES ═══
UNIT FILE                                  STATE           PRESET
accounts-daemon.service                    enabled         enabled
apache-htcacheclean.service                disabled        disabled
apache-htcacheclean@.service               disabled        disabled
apache2.service                            disabled        disabled
apache2@.service                           disabled        disabled
apparmor.service                           disabled        disabled
apt-daily-upgrade.service                  static          -
apt-daily.service                          static          -
apt-listchanges.service                    static          -
atftpd.service                             indirect        disabled
auth-rpcgss-module.service                 static          -
autovt@.service                            alias           -
avahi-daemon.service                       disabled        disabled
blueman-mechanism.service                  disabled        disabled
bluetooth.service                          disabled        disabled
```

```
294 unit files listed.


═══ PORTS OUVERTS ═══
Netid State  Recv-Q Send-Q Local Address:Port Peer Address:PortProcess
tcp   LISTEN 0      128          0.0.0.0:2222      0.0.0.0:*    users:(("sshd",pid=52862,fd=6))
tcp   LISTEN 0      128             [::]:2222         [::]:*    users:(("sshd",pid=52862,fd=7))


═══ CONFIG SSH ═══
Port 2222
PasswordAuthentication yes
#PasswordAuthentication yes
# PasswordAuthentication.  Depending on your PAM configuration,
# the setting of "PermitRootLogin prohibit-password".
# PAM authentication, then enable this but set PasswordAuthentication
#GatewayPorts no


═══ EXPORT DES RESULTATS ═══
Export terminé : audit_resultats.txt
```

Afin de démontrer la capacité à automatiser un audit de sécurité comme le ferait un analyste, un script Python nommé *audit.py* a été développé. Ce script exécute automatiquement plusieurs commandes d'audit essentielles et regroupe les résultats dans un fichier unique. La première partie du script récupère la liste complète des services installés sur le système via systemctl, permettant d'identifier rapidement les services actifs, désactivés ou en état statique. La seconde partie vérifie les ports ouverts grâce à la commande ss -tulnp, ce qui permet de confirmer que seul le port SSH personnalisé (2222) est exposé. Le script analyse ensuite la configuration SSH en extrayant les directives critiques telles que *Port*, *PermitRootLogin* et *PasswordAuthentication*, afin de vérifier la conformité du service avec les bonnes pratiques de durcissement. Enfin, l'ensemble des résultats est exporté automatiquement dans un fichier *audit_resultats.txt*, facilitant la traçabilité et l'intégration dans un rapport d'audit. L'exécution du script montre que toutes les commandes fonctionnent correctement et que l'audit automatisé fournit une vision claire et structurée de l'état de sécurité du serveur.

CONCLUSION

L'ensemble des opérations menées au cours de ce projet a permis de transformer un système initialement standard en un serveur réellement durci, surveillé et conforme aux bonnes pratiques de cybersécurité. Les différentes étapes — de l'inventaire des services à la configuration du pare-feu, en passant par la sécurisation de SSH, la mise en place de Fail2ban et la vérification des journaux — ont démontré la capacité du système à résister aux attaques les plus courantes, notamment les tentatives d'intrusion par force brute. Les tests réalisés, tels que les scans Nmap, les tentatives SSH échouées et l'analyse des logs, ont confirmé l'efficacité des mesures appliquées. Enfin, le développement d'un script Python d'audit automatisé a permis de prouver la capacité à industrialiser ces contrôles, comme le ferait un analyste SOC ou un administrateur système expérimenté. Le serveur est désormais minimal, cloisonné, surveillé et capable de se défendre de manière autonome, constituant ainsi une base solide pour un environnement sécurisé et professionnel.